

Sprint 4: DevOps & Quality Assurance Report

Project	A1 Academy: Online Learning & Tutoring Platform
Sprint	Sprint 4, the final sprint (30 September – 2 October 2026)
Role	DevOps / Quality Assurance: INKARAN (INKARAN001)
Repository	IT24101853-AkashD/A1-Academy (public)
Work covered	Pull requests #50 – #86 (32 merged PRs)
Report date	2 October 2026

1. Executive Summary

Sprint 4 focused on making A1 Academy **testable, secure and automatically deployable**. At the start of the sprint, Kafka was not reachable from the services, 8 backend tests were failing, deployments to Azure were manual, production secrets were committed to the public repository, and there was no static analysis.

By the end of the sprint:

Area	Start of sprint	End of sprint
Kafka messaging	Broken in Docker, absent in Azure	Working locally and on Azure Event Hubs ; verified end-to-end
Backend tests	182 tests, 8 failing	195 tests, 0 failing
Test gate in CI	None: failing tests could be merged	Tests block image build and deploy
Deployment	Manual az containerapp update	Automatic on merge to main , with restart and readiness check
Production secrets	Committed in a public repo and in use	Rotated ; stored as Azure Container App secrets
Static analysis	None	SonarCloud with a Quality Gate on every PR
Health monitoring	None	/health/live and /health/ready on all 5 services
Dependency updates	Manual	Dependabot with CI-validated PRs
Supply-chain security	Actions referenced by mutable tags	All 37 action references pinned to commit SHAs

Real defects found and fixed: 9 (3 functional bugs, 5 security vulnerabilities, 1 build defect), plus one security incident handled end-to-end (see §7).

2. System Under Test

Component	Technology	Hosting
Frontend	React + Vite	Azure Web App (a1-academy-frontend)
API Gateway	ASP.NET Core + YARP	Azure Container App a1academy-gateway
Auth, Admin, Teacher, Student services	ASP.NET Core 10 microservices	Azure Container Apps (a1academy-*), Express environment
Database	PostgreSQL 16	Azure Database for PostgreSQL Flexible Server
Messaging	Apache Kafka protocol	Docker (cp-kafka 7.5) locally; Azure Event Hubs (Standard) in production
CI/CD	GitHub Actions	Docker Hub images, OIDC deploy to Azure
Static analysis	SonarCloud	it24101853-akashdt / A1-Academy

Test tooling: xUnit, Moq, ASP.NET Core **WebApplicationFactory** (integration), coverlet (coverage), Vitest (frontend unit), Selenium / WebdriverIO (E2E), JMeter (load), actionlint and shellcheck (pipeline and script linting).

3. Work Completed

3.1 Kafka Integration (#50, #51, #52)

Item	Detail
Problem	The Kafka broker advertised only <code>localhost:9092</code> , so no container could reach it; services had no broker address configured; all four services shared one consumer group, so each event reached only one service.
Change	Two broker listeners (<code>kafka:29092</code> for containers, <code>localhost:9092</code> for the host), a broker healthcheck, configurable SASL/TLS client settings, one long-lived producer, and one consumer group per service.
Production	Azure Event Hubs Standard namespace <code>a1academy-kafka-sprint4</code> (Kafka endpoint), topic <code>test-topic</code> , a Send/Listen-only access key stored as a Container App secret.
Security fix	<code>POST /api/events/publish</code> was public and unauthenticated; it is now restricted to <code>Admin</code> (#52).

Verification

Test	Expected	Result
Local: publish 1 message to <code>test-topic</code>	All 4 services log <code>[KAFKA RECEIVED]</code>	✓ 4/4 services received it
Azure: broker connections	8 (producer + consumer × 4 services)	✓ <code>ActiveConnections</code> = 8
Azure: end-to-end publish	1 incoming, 4 outgoing messages	✓ <code>IncomingMessages</code> 1, <code>OutgoingMessages</code> 4
Anonymous publish after fix	401	✓ 401 in production
New endpoint tests (anonymous / Student / Admin)	401 / 403 / 200	✓ 3 tests pass; anonymous and Student tests fail on the old code

Evidence: [Sprint4-Kafka-Azure.md](#)

3.2 CI/CD Pipeline (#53, #54, #56, #57, #72, #83)

Pull request → Backend Tests → service build (no push) → SonarCloud Quality Gate
Merge to main → tests → build + push image (:sha) → deploy → stop/start → /health/ready = 200

Capability	Implementation
Test gate	Every service pipeline runs the full backend test suite before building; a failing test stops the build and the deploy (#54).
Automatic deploy	Reusable <code>deploy-containerapp.yml</code> ; Azure login via GitHub OIDC with a managed identity, so no password is stored in GitHub (#53).
Reliable rollout	The Express environment does not restart containers on update, so the deploy explicitly stops/starts the app and passes only when a new container is running (#56).
Readiness gate	The deploy also waits for <code>/health/ready = 200</code> , so a service that cannot reach its database fails the deploy (#65).
PR safety	PR builds never push images to Docker Hub, so unmerged code cannot reach <code>:latest</code> (#57).
Manual redeploy	A "Run workflow" button on every service pipeline.
PR checks for all PRs	A Backend Tests workflow on every backend PR; frontend lint and build on frontend PRs; a secretless image-tag fallback for Dependabot PRs (#72).
Supply chain	All 37 third-party action references pinned to full commit SHAs (#83).

Verification: all 5 services deployed automatically after merges #65, #73 and #80 and passed the readiness check; a manual `workflow_dispatch` run on `main` succeeded (build 2 m 39 s, deploy 1 m 23 s).

3.3 Test Repair and Test Gate (#54)

At sprint start, 8 of 182 backend tests failed. Investigation showed that **two of the three causes were real production bugs**, not outdated tests:

Failing tests	Root cause	Classification
6 deactivate/reactivate tests (HTTP 500)	The status change was saved, then the notification email was sent; an SMTP failure returned 500 for an action that had succeeded. Tests were also sending real email via Gmail.	Production bug
Register_WithTeacherRoleAndNoCategories	The "teacher must choose a subject" validation had been deleted (only its comment remained).	Production bug
Login_WithDeactivatedAccount	Message changed to "This Email is Deactivated contact the admin".	Wording regression

Fixes: the email is now best-effort (logged on failure); the subject validation is restored; the message is restored; tests use a mock email service. A regression test simulates SMTP failure; it **fails on the old code and passes on the new code**.

3.4 Health Checks (#65)

Endpoint	Checks	Used by
/health/live	The process responds	Liveness
/health/ready	The service can reach its database	Deploy pipeline, ops script

Tests: live → 200, ready → 200, and **ready → 503 when the database is unreachable** (the condition behind the 1 October login outage, §7.2).

3.5 Static Analysis: SonarCloud (#77, #79)

A CI-based SonarCloud scan replaces Automatic Analysis, which cannot analyse C#. The scan builds the backend, runs the tests with coverlet OpenCover coverage, uploads the results, and **fails the job if the Quality Gate fails**.

Metric	First CI analysis (1 Oct)	Current (2 Oct, 29e9a58)
Quality Gate	Passed	✓ Passed
Coverage	39.4 %	47.8 %
Cyclomatic Complexity	2004	1986
Cognitive Complexity	1131	1108
Maintainability Rating	A (Technical Debt Ratio 0.1 %, 296 min)	A (0.1 %, 276 min)
Vulnerabilities	43	18
Bugs	18	18
Duplication	10.1 %	8.1 %
Lines of code	12,821	11,402 (dead code removed)

The gate was effective during the sprint: in #78 it **caught a new regex without a timeout (S6444)** introduced by the OTP fix. The finding was resolved in #79.

3.6 Dependency Management (#59, #60, #61, #67, #73, #74, #75)

- **Dependabot** checks NuGet, npm and GitHub Actions weekly; minor and patch updates are grouped into one PR per ecosystem.
- **Breaking update caught by CI:** the grouped backend update (#66) failed to build. Root cause: EF Core *Design/Tools* moved to 8.0.31 while the services still compiled against EF Core 8.0.11 (CS1705). Fixed in #73 by referencing EF Core 8.0.31 directly in *Shared*.

- **Hidden build defect found:** a stray `A1Academy.TeacherService.csproj` inside the Auth folder shared Auth's `obj/` directory, so local restores could build Auth with an outdated package list. Removed in #73.
- **Coupled major versions** (EF Core, Npgsql, ASP.NET Core, IdentityModel, Application Insights) are excluded from Dependabot, because they must be upgraded together (see §8.2).
- 20 backend packages, 15 frontend packages, 10 GitHub Actions and 3 test-tooling packages updated; all deployed and verified healthy.

3.7 Repository Hygiene (#58, #80)

- `backend/.dockerignore`: the build context dropped from **1.3 GB to 660 KB**, and host `bin/obj/` folders can no longer be copied into images.
- **47 dead files removed:** 26 one-off codemod scripts, the `scratch/` folder (which contained old credentials and an accidentally committed nested Git repository), and leftovers of the old monolith. Verified: backend builds and 195/195 tests pass; frontend lints and builds; `docker compose config` is valid.

3.8 Operations Script (#81, #82)

`scripts/devops-azure-setup.sh` was rewritten. The old version would have overwritten production secret references with plain text and targeted the wrong resource group.

Command	Purpose
<code>status</code>	Read-only report: image, container start time, secret-vs-plain-text check, <code>/health/ready</code>
<code>kafka</code>	Idempotent Event Hubs setup
<code>secrets</code>	Create or rotate secrets via hidden prompts; changes only what is supplied
<code>restart [app]</code>	Stop/start, wait for a new container and <code>/health/ready = 200</code>

Verified with a mocked Azure CLI (only supplied secrets change; secret values printed 0 times), `shellcheck` and `bash -n`, then used in production to clean the gateway (§7.1).

4. Test Summary

4.1 Automated Test Suites

Suite	Tool	Tests	Result	Runs in CI
Backend unit + integration	xUnit, WebApplicationFactory	195	✓ 195 passed, 0 failed	Every backend PR and every deploy
Frontend unit	Vitest	158	⚠ 127 passed, 31 failed (pre-existing, see §8)	Not yet a gate
Backend E2E	Selenium	1 flow	Manual (needs a live environment)	Excluded (<code>Category=E2E</code>)
Frontend E2E	WebdriverIO	3 specs	Manual	No
Load	JMeter	3 profiles	Verified in an earlier sprint	No

Backend test count over the sprint: 182 (8 failing) → 185 (+3 events endpoint) → **186 all passing** (+1 SMTP regression) → 189 (+3 health) → **195** (+6 OTP/upload security).

4.2 Tests Added This Sprint

Test	Verifies	Fails on old code?
<code>Publish_WithoutToken_ReturnsUnauthorizedAndPublishesNothing</code>	Events endpoint requires login	✓ Yes
<code>Publish_AsStudent_ReturnsForbiddenAndPublishesNothing</code>	Events endpoint is Admin-only	✓ Yes

Test	Verifies	Fails on old code?
Publish_AsAdmin_PublishesToKafka	Admin can still publish	— (guard)
DeactivateUser_WhenNotificationEmailFails_StillSucceeds	SMTP failure does not return 500	✓ Yes
Health_WithWorkingDatabase_ReturnsHealthyAnonymously (×2)	live/ready return 200	—
Ready_WhenDatabaseUnreachable_Returns503ButLiveStaysUp	Readiness detects DB outage	—
VerifyOtp_AfterFiveWrongGuesses_DiscardsTheCode...	Signup-code brute-force limit	✓ Yes
VerifyResetOtp_AfterFiveWrongGuesses_DiscardsTheCode...	Reset-code brute-force limit	✓ Yes
Register_TeacherDocumentWithPathTraversalName_IsSavedInsideUploadsFolder	Upload path traversal blocked	✓ Yes
SendOtp_StoresAFiveDigitNumericCode	Code format unchanged for the UI	— (guard)
VerifyOtp_AfterFourWrongGuesses_StillAcceptsTheCorrectCode	Real users are not locked out early	— (guard)
SendOtp_IssuingANewCode_ResetsTheWrongGuessCounter	A new code resets the limit	— (guard)

Each security fix was confirmed by running its regression tests **against the previous code (they fail)** and **against the fix (they pass)**.

5. Defect Log

ID	Severity	Defect	Found by	Fix	PR
D-01	High	Unauthenticated <code>POST /api/events/publish</code> let anyone write to the paid Event Hubs	Manual review	<code>[Authorize(Roles = "Admin")]</code> + tests	#52
D-02	High	Deactivate/reactivate returned 500 when email failed, after the change was already saved	Failing tests	Best-effort email + regression test	#54
D-03	Medium	Teachers could register without selecting a subject	Failing test	Validation restored	#54
D-04	Low	Deactivated-login message wording regression	Failing test	Message restored	#54
D-05	Critical	Signup/reset codes generated with predictable <code>System.Random</code>	SonarCloud (S2245)	<code>RandomNumberGenerator</code>	#78
D-06	Critical	No limit on wrong code guesses (5-digit codes brute-forceable → account takeover)	Code review during D-05	Max 5 attempts per code	#78
D-07	High	OTP codes written to server logs in plain text	Code review during D-05	Log lines removed	#78
D-08	High	Path traversal via uploaded qualification-document file name	SonarCloud (S2083)	File-name sanitising + path check	#78
D-09	Medium	Stray <code>.csproj</code> in the Auth folder corrupted Auth's package restore	Dependabot build failure	File removed	#73

6. Security Hardening Summary

Control	Status
Secrets out of source code (<code>appsettings.json</code> blanked)	✓ #55
Production secrets as Container App secrets (<code>secretref</code>)	✓ All: JWT, DB, admin, Kafka, SMTP (verified with <code>status</code> : no plain-text secrets on any app)
No credentials in GitHub (OIDC federated login)	✓ #53
Admin-only internal endpoints	✓ #52

Control	Status
Secure OTP generation, attempt limit, no logging	✓ #78
Upload path sanitising	✓ #78
Secrets passed to scripts as environment variables, not interpolated	✓ #79
Actions pinned to commit SHAs	✓ #83
PR builds cannot publish images	✓ #57
Database firewall limited to Azure services	✓ Verified

7. Incidents

7.1 Leaked Production Secrets (1 October 2026)

Finding	<code>AuthService/appsettings.json</code> in the public repository contained the production database password, the JWT signing key and the bootstrap admin password, and all four services were using them .
Impact	Anyone could read the database, forge an Admin token, or log in as Admin.
Response	(1) Confirmed exposure without printing secrets. (2) Generated new values. (3) Stored them as Container App secrets. (4) Changed the database password. (5) Set a new admin password directly in the database. (6) Removed the values from source (#55).
Verification	Old admin password → 401; new admin login → token; cross-service call with new token → 200; Kafka back to 8 connections.
Follow-up	Unused secrets were also found as plain text on the gateway; they were removed with the new ops script on 2 October. The last plain-text secret (SMTP) was replaced the same day with a new sender account and app password; <code>status</code> now reports no plain-text secrets on any app.

7.2 Login Outage During Rotation (~30 minutes, 1 October 2026)

Symptom	All logins returned HTTP 500 after the secret rotation.
Root cause	On the Azure Container Apps Express environment, <code>az containerapp update</code> changes the configuration but does not restart the running container , and revision restart is unsupported. The containers kept the old database password.
Resolution	Stop/start each app; confirmed via container start time and login tests.
Prevention	The deploy pipeline and the ops script now always stop/start and verify a new container plus <code>/health/ready</code> (#56, #65, #81).

8. Project Close-out

Sprint 4 is the **final sprint** of the project. This section lists what remains at close.

8.1 Actions to Complete Before Hand-over

#	Item	Owner	Status
1	A Gmail app password was committed in the removed <code>scratch/remove_secrets.js</code> (still in Git history) and the SMTP password was plain text on 4 services	DevOps	✓ Done (2 Oct) : emails now sent from a new account (<code>karanaathi001@gmail.com</code>) with a new app password stored as the <code>smtp-password</code> secret; all 4 services restarted healthy; production OTP send verified (HTTP 200). The leaked password is no longer used; its owner should still revoke it.
2	Manual Gateway CI run to exercise the pinned Docker/Azure actions end-to-end	DevOps	⌚ Pending

#	Item	Owner	Status
3	Decide whether to keep the uploaded files committed under <code>backend/A1Academy.API/uploads/</code>	Team	⌚ Pending

8.2 Known Limitations at Project Close

These were identified during the sprint but are outside the remaining project time. They do not block the delivered features.

#	Limitation	Impact	Recommended fix
4	31 frontend unit tests fail because they target the pre-redesign UI (the features still exist and work)	Frontend changes are not covered by an automated gate	Update the selectors to the new UI, then add the suite as a CI gate
5	Containers run as root (SonarCloud S6471, 7 findings)	Larger impact if a container is compromised	Add a non-root <code>USER</code> to the Dockerfiles, with write access to <code>uploads/</code>
6	SonarCloud Security E / Reliability D on legacy code (18 vulnerabilities, 18 bugs, mainly frontend and Dockerfiles)	Lower code-quality rating on code outside this sprint's scope	Work through the SonarCloud issue list by severity
7	README and backend E2E defaults still describe the old monolith (<code>A1Academy.API</code> , port 5123)	Setup instructions can mislead new developers	Update to the microservice layout (gateway on port 5100)
8	Coupled major upgrades (EF Core 10, Npgsql 10, JwtBearer 10, App Insights 3) not applied	Running on supported 8.x packages; no functional impact	Upgrade them together in one change, then run the full test suite
9	No branch protection on <code>main</code>	Quality checks report failures but do not prevent a merge	Require Backend Tests and SonarCloud status checks

9. Recommendations for Future Maintenance

- 1 Ask the owner of the old Gmail account to revoke the leaked app password (it is no longer used by production, but remains in Git history).
- 2 Enable branch protection on `main` so the existing quality checks are enforced rather than advisory.
- 3 Use `scripts/devops-azure-setup.sh status` as the first check when anything looks wrong in production, and `restart` after any configuration change.
- 4 Keep merging Dependabot PRs only when their checks are green; plan the .NET 10 package upgrade as a single change.
- 5 If the platform continues, move the Container Apps from the Express environment to a standard one (supports revisions, restart and log streaming).
- 6 **Cost:** the Azure Event Hubs Standard namespace (~US\$22/month) and the Container Apps draw on the student subscription credit. Delete the `A1-Academy-RG` resources (or at least the Event Hubs namespace) once the project is assessed and no longer needs to run.

Appendix A: Merged Pull Requests

PR	Change
#50	Connect services to Kafka locally and via Azure Event Hubs
#51	Kafka evidence
#52	Restrict events publish endpoint to Admins
#53	Auto-deploy backend Container Apps on merge (OIDC)

PR	Change
#54	Fix 8 failing tests (3 bugs) and gate CI on tests
#55	Remove committed secrets; deploys restart the app
#56	Run deploy verification on the runner; manual redeploy
#57	Only publish Docker images from <code>main</code>
#58	<code>.dockerignore</code> for the backend build context
#59	Dependabot
#60, #61, #67, #74, #75	Dependabot updates (Actions, frontend, test tooling)
#65	Health endpoints; readiness-gated deploys
#72	PR checks that work for Dependabot; Backend Tests workflow
#73	Backend package updates with EF Core alignment; stray csproj removed
#77	SonarCloud CI analysis and Quality Gate
#78	Secure OTP codes and upload path
#79	Clear the Quality Gate (regex timeout, secret in script)
#80	Remove 47 dead files
#81, #82	Safe Azure setup / ops script
#83	Pin GitHub Actions to commit SHAs
#84	This report
#85	Setup script can switch the email sender account
#86	Default sender address updated; report close-out

Appendix B: How to Re-verify

```
# Backend tests (same command as CI)
dotnet test backend/A1Academy.Tests/A1Academy.Tests.csproj --configuration Release --filter "Category!=E2E"

# Local Kafka end-to-end
docker compose up -d --build
docker exec -it local_kafka bash -c \
  "echo hello | kafka-console-producer --bootstrap-server localhost:29092 --topic test-topic"
docker compose logs auth admin teacher student | grep "KAFKA RECEIVED"

# Production status (Azure Cloud Shell)
bash scripts/devops-azure-setup.sh status
```

SonarCloud dashboard: https://sonarcloud.io/project/overview?id=IT24101853-AkashD_A1-Academy